Enforcing The Chinese Wall Security Policy in Security-Enhanced Linux

by

Calum Cardownie

In partial fulfilment of the
requirements for the degree of
Bachelor of Science
in
CS408: Individual Project

University of Strathclyde Glasgow

Department of
Computer and Information Sciences

March 2026

Abstract

The abstract is a bird's eye view of the project. It should not exceed one page. Mention the scope and objectives of the project, the methodology used,the main findings, and significance of your results.

Acknowledgements

I would like to thank

Contents

1 Introduction **1**
1.1 Background . . . 1
1.2 Project Aim . . . 1
1.3 Objectives . . . 2
1.4 Report Format . . . 2

2 Literature Review **3**
2.1 The Chinese Wall Policy . . . 3
2.1.1 The Brewer-Nash Model . . . 3
2.1.2 Intricacies of the Chinese Wall . . . 3
2.2 Chinese Walls in Adjacent Systems . . . 4
2.2.1 Foley's Unix Model . . . 4
2.2.2 Cloud Computing . . . 5
2.2.3 Workflow Management . . . 6
2.2.4 Financial Institutions . . . 7
2.3 Security-Enhanced Linux . . . 7
2.3.1 Mandatory Access Control System . . . 7
2.3.2 Security Architecture . . . 8
2.3.3 Policy Module System . . . 9
2.3.4 MLS In SELinux . . . 9
2.4 Origin and Role of Security-Enhanced Linux . . . 10
2.4.1 The NSA's Creation of SELinux . . . 10
2.4.2 Inclusion of SELinux in the mainline Linux kernel . . . 10
2.4.3 Red Hat Enterprise Linux . . . 10

3 Specification **11**
3.1 Methodology . . . 11
3.1.1 Agile . . . 11
3.1.2 Waterfall . . . 11
3.2 Project Stages . . . 11
3.2.1 Understanding SELinux & Brewer-Nash . . . 12
3.2.2 Static Chinese Wall . . . 12
3.2.3 Dynamic Chinese Wall . . . 12
3.2.4 Testing & Evaluation . . . 12
3.3 Analysis . . . 12
3.4 Requirements . . . 13

4 Design **15**
4.1 Virtual SELinux Environment . . . 15
4.2 Policy Design . . . 15
4.2.1 Object Policy Modules . . . 15
4.2.2 Subject Policy Modules . . . 15
4.2.3 cwalld Policy Module . . . 16
4.3 System Design . . . 17
4.3.1 Tailing the Audit Daemon . . . 17

4.3.2 Subject Label Alteration at Runtime . . . 17
4.3.3 Flowchart . . . 18
4.3.4 UML Diagram . . . 18
4.4 Assisting Binaries . . . 18
4.4.1 cwalld-init . . . 19
4.4.2 cwalld-tail . . . 19

5 Implementation **20**
5.1 Technology Selection . . . 20
5.1.1 Language . . . 20
5.1.2 Packages . . . 20
5.2 Version Control . . . 21
5.3 Policy Modules . . . 21
5.4 Internal Packages . . . 23

6 Verification & Validation **25**
6.1 Testing Suite . . . 25
6.2 Testing Constraints . . . 25

7 Results & Evaluation **26**
7.1 Evaluation Process . . . 26
7.2 Results of Evaluation . . . 26
7.3 Returning to the Research Questions . . . 26
7.3.1 RQ1 . . . 26
7.3.2 RQ2 . . . 26
7.3.3 Objective 1 . . . 26
7.3.4 Objective 2 . . . 26

8 Discussion & Reflection **27**
8.1 Interpreting the Results . . . 27
8.2 Reflection . . . 27
8.3 Challenges . . . 27
8.4 Limitations . . . 27
8.5 Future Work . . . 27

9 Conclusion **28**

A Appendix **30**
A.1 cwalld design . . . 30
A.2 Policy Modules . . . 31
A.3 Red Hat . . . 33
A.4 Auditd logs . . . 34

1 Introduction

1.1 Background

"The more you know, the less you can share" serves the basis for the Chinese Wall (Brewer-Nash) model. The policy deems that a subject (a daemon/process) in the system loses its read/write privileges, as it continues its operations. Conflict of Interest (`CoI`) classes are used to dictate restrictions, with the goal of the policy to stop the subject from sharing sensitive information between objects (a file) that are conflicting with each-other [1]. The dynamic nature of the Chinese Wall makes it an intriguing security policy, standing in stark contrast from typical static security policies.

SELinux is a well-known solution to all sorts of security concerns threatening servers and personal devices. SELinux implementing *Red Hat* (IBM) have solidified themselves as the industry choice for secure hosting solutions, being a leading operating system used by over 90% of Fortune 500 companies for its quality privacy guarantee [2].

1.2 Project Aim

Implementation of the Brewer-Nash Model, by leveraging the *mandatory access control* system introduced by Security-Enhanced Linux, is the primary goal of this project.

The Chinese Wall has received a noticeable lack of attention in the space surrounding SELinux. While providing an implementation for SELinux, this report delves into the use cases of this specific policy, where it has succeeded in the past, and what its inclusion in SELinux allows.

Previous research into both Chinese Wall effectiveness and SELinux was factored in the design process, along with hands on experimentation and prototyping of different solutions. The development of the Chinese Wall daemon should serve to open possibilities of dynamic policies in the otherwise static SELinux, and potentially lead the way in future security solutions.

To enforce this policy model in SELinux, policy modules must be compiled into the kernel via the security server and work in tandem with the designed Chinese Wall Security Daemon, developed to be capable of enforce dynamic label alterations to monitored subjects in a directory. A lattice based system is used to transition subject labels based on their read and write history accordingly, which should suffice to handle all cases of the Chinese Wall. Finally, this allows the SELinux Access Vector Cache (AVC) to handle the restrictions on a kernel level, successfully locking the system down to

`CoI` breaches.

1.3 Objectives

1.1 Create a suitable Virtual Environment for SELinux.

1.2 Understand the principles of:

1.2.A The Chinese Wall Security Model.

1.2.B SELinux's Security Server & Policy Module System.

1.3 Implement a static implementation of the Chinese Wall Policy, confined by SELinux.

1.4 Develop a system daemon capable of monitoring subjects and their operations on objects.

1.5 Update daemon to dynamically alter labels, allowing SELinux to enforce the Chinese Wall policy.

1.6 Fully integrate the Chinese Wall Security Daemon into SELinux's environment, complete with its own policy module.

1.7 Test and analyse the capabilities and limitations of the Chinese Wall Security Daemon.

1.8 Analyse the difficulties that arose with development and conclude why development in this area has been lacklustre.

1.4 Report Format

The report is structured in an sequence appropriate to the process undertook addressing this challenge, detailing background research, solution design, implementation and testing, followed by results and evaluation.

2 Literature Review

2.1 The Chinese Wall Policy

2.1.1 The Brewer-Nash Model

The Chinese Wall Model - or Brewer-Nash Model - is a security model that aims to prevent information flow between datasets that are in *conflicts of interest* (`CoI`) [1]. The Brewer-Nash Model provides a mathematical format that is based on the larger Chinese Wall policy. As opposed to the classic multi-level security Bell LaPadula model, which enforces *"no read up, no write down"* [3], the Chinese Wall model allows for information flow freely until a subject attempts to read from a `CoI` object. Upon this access, the system shall dynamically revoke their write permissions to other objects in the `CoI` group, creating a "wall" in-between them. Consider the following scenario:

A data server stores information on Bank A and B, and Tech Company A and B. These are in a `CoI` relation with their respective counterparts. If a user approaches the dataset, they are initially able to access any object. As far as the system is concerned, this user is free as they have no prior knowledge of either companies. Suppose the user has read from Bank A, the situation develops - the user now possesses information that, deemed by the Chinese Wall, should not be allowed to reach Bank B, as they in a `CoI` relation with Bank A. The Wall revokes the write access from the user in regard to Bank B. Now information *cannot* flow from Bank A to B. The system is constructed to definitively prevent this leakage scenario. It should also be noted that once information from Bank A is read, it cannot be shared to Tech Company A or B. In that scenario, a different subject could read from Tech Company A and write to Bank B, as they are not in conflict, exploiting the rules of the Chinese Wall.

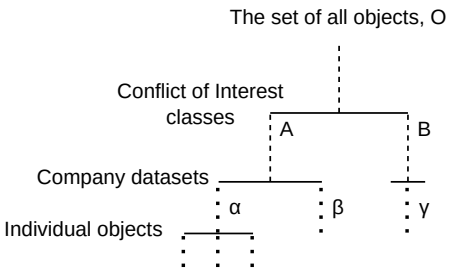


Figure 1: The composition of objects

2.1.2 Intricacies of the Chinese Wall

Brewer & Nash's rules demonstrated the Chinese Wall as more as a mathematical concept than a policy. They broke it down into the following rules, influenced by Bell-LaPadula:

- **Simple Security Property**: Subject `S` can read object `O` only if `O` is in the same Company

Dataset (CD) as an object already read by S, or if O's CD is in a different CoI group from all CDs of objects already read by S.

- ***-Security Property**: Subject S can write to an object O only if S can read O **and** all objects O' read by S are in the same CD as O.

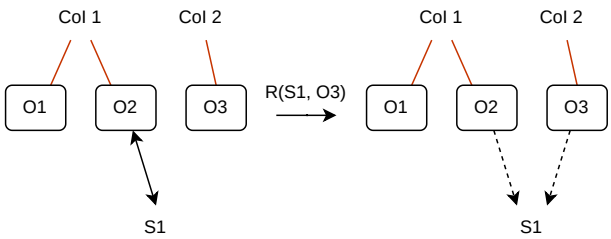


Figure 2: Demonstration of the **-property*

Note in Figure 2, where a full line represents read/write access and a dotted line represents read access; Once a read is performed on O3, the **-property* dictates that subject S1 must lose its write access to O2.

The Brewer-Nash model suffers from a lack of clarity in some areas, leaving readers split on interpretations of certain definitions in the paper. The **-property* for one, leaves it unclear if write access implies read access. As such, this report will outline a clear understanding the Chinese Wall and follow that definition.

After the Brewer-Nash model was communicated, another paper was published once again by Brewer & Nash, but also T.Y. Lin, who presented them with potential improvements on their model after their original paper, leading to the *Aggressive Chinese Wall* [4]. This idea, trying to disprove the assumption that the conflict of interest is an equivalent relation, has since been accepted into the mainstream.

2.2 Chinese Walls in Adjacent Systems

To understand the effect that a new Chinese Wall can have, other ventures in adjacent systems should be investigated and evaluated. Unix, Cloud, Workflow management & even the Financial world will be discussed in the following.

2.2.1 Foley's Unix Model

A Chinese Wall model implementation was made in standard Unix, leveraging its *Discretionary Access Control* (DAC) security system also adopted by Linux and macOS. The 1997 Unix proof by S.N. Foley built upon T.Y. Lin's Aggressive Chinese Wall Model, illustrating the possibility of its creation in with DAC [5]. The Unix proof features a CoI matrix, detailing a non-transitive version of the CoI

relations. Foley's concept focused on the restriction of users, preventing a user of the computer from spreading information enforced via their user ID and group ID. DAC is defined such that objects and their privileges are managed by their creator, and the super-user can access and alter anything. DAC enforces based on the user ID and any groups with which they belong. While DAC brings about great flexibility, the models' reliance on ownership often leads to uncontrolled privilege propagation. It is known to be difficult to measure the security of the DAC model, and in some cases it is undecidable [6].

2.2.2 Cloud Computing

Chinese Walls have been implemented in Cloud Computing against various threat models. Cloud Computing involves many Virtual Machines (VMs) running on one core system, with the virtual machine monitor, or *"hypervisor"* acting as the delegating force of the computers' hardware to the VMs. Each VM is a separate Operating System (OS), meant to be completely independent of the other VMs on a machine.

sHype Hypervisor

The sHype *Mandatory Access Control* system was added to the Xen hypervisor to defend against information sharing between VMs by R. Sailer et al [7]. The hypervisor prevents inter-VM communication with kernel hooks, intercepting and evaluating every attempt to communicate across VM's. Whilst claiming to be a Chinese Wall, the sHype architecture does not truly capture the notion of Brewer & Nash's Model, instead focusing on static *"Chinese Wall types"*. Regardless, sHype does successfully prevent against `CoI` leakages, in the case of insider activities or inter-VM attacks.

Chinese Wall Central Management System

Inter-VM attacks can happen if a VM on the system is breached, and can allow a targeted attack on another VM, even a compromised hypervisor. To eliminate the possibility of inter-VM attacks from competitors, a different Chinese Wall security model was implemented. The CWCMS, operating above the *Kernel-based Virtual Machine*[1] level via installed control agents, with a sole focus of actively preventing `CoI` breaches was designed by Tsai et al [8]. Once a VM in a `CoI` group is running on a physical host, the Wall prevents other VMs belonging to the same `CoI` group from

[1] KVM allows the Linux kernel to act as a hypervisor.

being scheduled on the same machine in advance. This is a pre-arranged decision made by graph colouring, as opposed to sHype which simply attempts to deploy it on different systems until one is satisfactory. This effectively eliminates the risk of inter-VM attacks in these systems. Similar to sHype, CWCMS also lacks dynamic label profiling, resolving to a statically enforced, yet successful, policy model.

Security-Awareness VMs Management Scheme

Finally, a dynamic Wall was created in Yu et al's SVMS system [9]. SVMS aims to eliminate intrahost *side channel attacks*, where malicious users extract private information by reading from shared data caches on the host machine. Yu et al address this with two techniques: Preventing simultaneous execution, and a more unique advance with VM placement and migration solutions based on VM traces. These VM traces are accumulated by tracking the *aggressive conflict of interest relation* and *aggressive in ally with relation*, they create a dynamic policy model faithful to the Brewer-Nash model, proving that the rules meet the simple-security property and *-security property.

All models, while different, agree that the *"Chinese Wall"* for Cloud involves preventing conflicting resources from running at the same time. Whilst not exactly cohering to the Brewer-Nash model, they all manage to succeed in their endeavours to create a Chinese Wall.

2.2.3 Workflow Management

Beyond virtualized environments, the Chinese Wall model has also successfully been implemented in workflow management systems. *Workflow Management Systems* (WfMS) are intrinsically network-based applications, potentially hosting multiple conflicting company datasets. As such, a secure WfMS must implement security features, specifically targeting information confidentiality as a main point of effort. The Chinese Wall security model can be leveraged to prevent conflict of interest leakage in this environment. The authors proposed and implemented a *Chinese Wall Security Policy Specification Language* in Java [10]. The paper mentions that *Role Based Access Control* (RBAC) is unable to implement general cases of the Chinese Wall, as it has issues implementing the Brewer-Nash simple security property in dynamic contexts, supporting the premise that the dynamic nature of the Chinese Wall is difficult to implement with standard methods.

2.2.4 Financial Institutions

Chinese Walls serve as a pillar of compliance in the financial sector. The ethical policy, more commonly just referred as *The Wall* in finance, is a commonplace measure that should theoretically and practically prevent misuse of information leakage in banks [11] and other financial management firms. Thus, the Wall is more attuned to person-level restrictions as opposed to system-wide enforcement as is present in modern considerations of the Wall. While entirely different from modern systems, it helps to understand the origin of the Wall, and that it aimed to prevent `CoI` leakage of strictly confidential information.

2.3 Security-Enhanced Linux

As the project aims to implement the Chinese Wall in SELinux, it's important to understand the system SELinux provides.

2.3.1 Mandatory Access Control System

Security Enhanced Linux implements a *Mandatory Access Control* (MAC) system, providing a policy-driven security layer extended beyond the classic DAC. Utilisation of labels - applied to both objects and subjects - and verbose policy modules provide the OS great freedom in restriction and enforcement. The *Security Context*, or *label* of an object/subject takes the form `user_u:role_r:type_t:s0` and can be viewed with the *-Z* flag when using *ls* or *ps*[2].

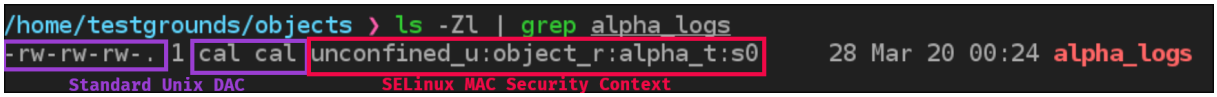


Figure 3: Security Context of an object

The Security Context consists of:

- **User** (`user_u`): Used to give the confine specific Linux users to a class, granting them simple privilege differences. Examples include `guest_u`, `user_u` or `staff_u`.
- **Role** (`role_r`): Used to confine users to roles, implementing role based access control.
- **Type** (`type_t`): Used to restrict subjects based on their domain type. The most specific field a policy can target.

[2] *ls* and *ps* are standard Unix commands to list objects and processes respectively.

- **Level** (`s0`): Used to enforce classes between types. It can be used to seperate VM's and such from sharing types in a *Multi-Level Security* context.

For instance, a simple policy may be that an object of type `httpd_t` can only be operated on by a subject of type `httpd_t` and not `sshd_t`. This provides strong mitigation against broken access control damages, as subjects can only access objects that they are contained to by SELinux's security server. In a case where a subject gets hijacked, it is still only restricted to the domain it originally had on the system.

2.3.2 Security Architecture

Being based off of the Flux Advanced Security Kernel (FLASK) security architecture for flexible nondiscretionary access controls, the architecture of SELinux is split into 2 main bodies:

- Policy enforcement via the Access Vector Cache (AVC)
- Policy decision-making via the policy repository and security server

The AVC serves as the main denial body, instantly able to deny a process on a cache hit. On a cache miss, the kernel briefly blocks the process as the syscall is carried out and the AVC enforces the denial / allows the syscall [12].

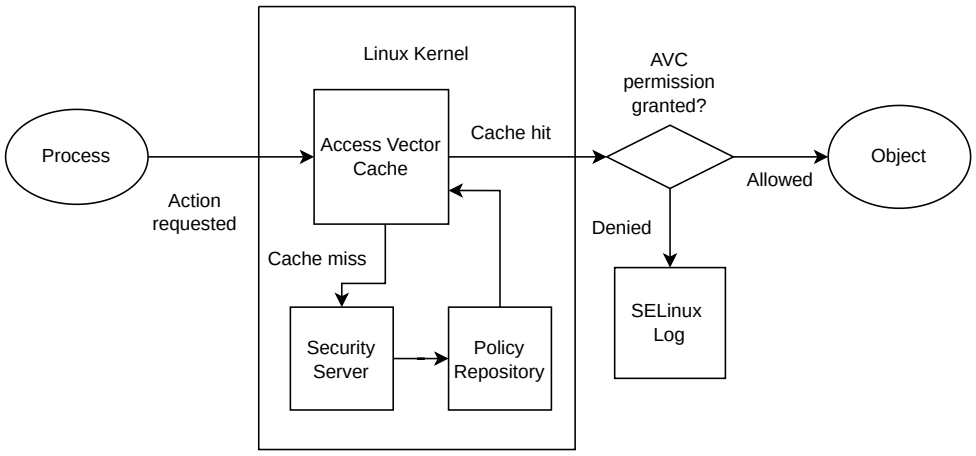


Figure 4: SELinux Components

2.3.3 Policy Module System

The *policy modules* (PMs) that SELinux provides are solely controlled by the super-user. Red Hat 9 by default has **440** modules, ranging every domain in the system. The *policycoreutils* package introduces developer tools to install and alter PMs on the system, calling *sepolicy generate –init* from the command line generates boilerplate for the policy including:

- Type Enforcement *(.te)* file: Unique syntax notates dependencies and designs rules, introduced to restrict the new labels.
- File Contents *(.fc)* file: Details the file contents related to the policy.
- RPM Spec *(.spec)* file: Installs the policy into the kernel, including labelling, the interface file and associated man page of the policy.
- Interface *(.if)* file: Defines the interfaces for the types generated in the type enforcement file, allowing policies to reference each-other.
- Shell Script *(.sh)* file: A script to be run by the super-user to compile and install the policy module. Under the hood, various commands are executed, eventually calling *semodule -i* to complete installation.

Once installed, PMs are persistent, and restrict based on their domain while SELinux is in *Enforcing* mode. SElinux also supports a *Permissive* mode, where denials are simply logged and not enforced, useful for testing at the cost of risk in the system. The *sepolicy generate* command includes a *permissive* line that must be removed from each *.te* file for the same reason.

2.3.4 MLS In SELinux

Red Hat has created the *Bell-La Padula* model in SELinux. It can be enabled and on reboot, labels are added to everything in the system according to their MLS clearance level (top-secret, confidential...). The implementation uses both the user field and level field to restrict them based on sub-sections within that range of level.

2.4 Origin and Role of Security-Enhanced Linux

2.4.1 The NSA's Creation of SELinux

SELinux is adopted by many distributions of Linux, including Red Hat Enterprise Linux (RHEL), Fedora and even mobile operating system giant Android. The origin of SELinux can be attributed to the *National Security Agency* (NSA)'s workings on a series of books called the Rainbow books - A series of Computer Security standards and guidelines by the United States Government. They published one and created a second (unpublished) book that included a formal SELinux model and associated evaluation evidence prototype. SELinux was a demonstration that mandatory access control was viable and could be added to the Linux kernel. The NSA, along with NAI Labs were responsibile for using FLASK to integrate MAC controls into the Linux kernel [13][14].

2.4.2 Inclusion of SELinux in the mainline Linux kernel

Linux, as an OS was able to adopt this because of its commitment to software freedom and ethical use of technology, originally being an open-source derivation from the Unix that was locked down by AT&T's IP. Linus Torvalds combined his Linux kernel with the GNU system tools by the GNU Project (Richard Stallman and various developers) to create GNU/Linux [15]. Linux was built under the *GNU General Public Licence*, where all code in the system had to be free and accessible. This open-source philosophy was a key factor enabling SELinux's integration into the mainline kernel in the 2.6 series in December 2004 [16].

2.4.3 Red Hat Enterprise Linux

The impact of Linux is huge, with 85% of smartphones [17] and 96% of top 1 million websites [18] powered by the free OS. Tech Giant IBM produced RHEL has a 33% market share in worldwide operating systems [19] (see Figure 11), no doubt because of their commitment to reliability, stability and security.

As one of many distributions of Linux, RHEL is a unique as a subscription based distribution, with a target audience of companies expecting nothing less than the finest. SELinux is clearly a lucrative avenue for development, and the introduction of new and unique security policies could yield various results.

3 Specification

3.1 Methodology

The decision to adhere to a methodology early in development helps set up consistent and satisfying progress over the life of the project. As this project was undertaken as a solo developer, the decision of methodology was not as crucial as a team setting. Still, the project lifecycle followed is more closely attuned to the agile principle.

3.1.1 Agile

Agile methodology focuses on multiple iterative stages, constantly evaluating the progress and direction of the project, and tuning decisions to reach the solution. As SELinux is a system with predefined capabilities and limitations, various different methods were used throughout to understand the boundaries and prototyping was updated accordingly. Experimentation in SELinux was carried out simultaneously alongside research, allowing accumulated insight to be backed by personal experience, and a more complete and satisfying solution.

This agile process was accompanied by a simple TUI kanban board, easily conveying the stage of the project as well as next steps and currently occupied tasks. This allowed for a more fulfilling lifecycle of an idea.

3.1.2 Waterfall

Waterfall involves a predefined set of requirements, of which progress is made solely to the final objective. This methodology benefits experience, where familiarity with the project environment allows decisions to be made far in advance. Waterfall usually has issues with bugs, as testing is only a focus in the later stages of development. As this is a project within time constraints and a single developer, agile was selected.

3.2 Project Stages

The project was split into 4 main stages:

3.2.1 Understanding SELinux & Brewer-Nash

This stage would encompass both researching and experimentation the main topics. A VM was set up, that would be used to deploy and test the product throughout the project. The boundaries of SELinux would be probed, with different avenues being evaluated and noted. Brewer-Nash would also be studied, coming to terms with the complexities and nuances of the policy; more complex than it seems at the first glance.

3.2.2 Static Chinese Wall

The first milestone of the project involved creating a static implementation of the Wall. This stretch aimed to prove that the SELinux type enforcement was verbose and specific enough to constrain a subject to specific allowances and denials. The phase was marked complete with the necessary policy modules installed to restrict specific subjects from specific objects, mimicking the Chinese Wall & using simple test daemons to confirm its effectiveness.

3.2.3 Dynamic Chinese Wall

The longest stage, involved achievement of the dynamic Chinese Wall by way of creating the *Chinese Wall Daemon*, *cwalld* and its surrounding policy modules. This phase closely embodied the agile methodology, as the daemon was built step by step, ontop of the already working static wall policies.

3.2.4 Testing & Evaluation

This phase involved testing the constraints and abilities of the final product. Unit testing, benchmarking and fitness testing were all applied to effectively evaluate functionality and overall success of the project. The entire project journey was evaluated, and limitations of the end product were also assessed.

3.3 Analysis

To enforce a dynamic security policy, it's natural to deduce that some sort of process must be constantly running to be capable of enforcing said dynamism. During experimentation on the boundaries of SELinux, it was surmised that the most effective way to leverage its MAC system was to change the type field of the security context on both subjects and objects. The user, role and

level fields of the subjects/objects were not sufficient to enforce a security policy, as policy modules were unable to be compiled to enforce restrictions based entirely on said fields.

It should be noted that policy modules are unable to be added to the SELinux security server at runtime, as it requires a complete re-compile of the security server and kernel. This operation is capable of taking anywhere between 4 and 8 seconds - unrealistic at runtime for a background process. Thus, policy modules cannot not be compiled while the system is running.

Further experimentation on the properties of the type field of the label preceded the philosophy that would be the main premise of the Chinese Wall Daemon. Pre-compiled policy modules for all scenarios, and a daemon that altered the labels of subjects at runtime according to their history of operations and the Chinese Wall policy. This daemon would also need to be fully integrated into SELinux's system, running under its own `cwalld_t` type rather than `unconfined_t`.

3.4 Requirements

Requirements specified early in the agile cycle follow the priority categories principle. Requirements are split into 4 categories:

- **Must** have - features that must be implemented to achieve the goal.
- **Should** have - features that should be implemented to develop the solution.
- **Could** have - features that could be implemented but are not priorised.
- **Won't** have - features that were considered but decided against.

These requirements were solidified after considering the required functionality of the product in depth. While the requirements were decided from the beginning, the means of which to complete them was left ambiguous, in line with agile structure.

Code	Requirement	Priority
FR1	`cwalld` must alter necessary configurations in the system before running.	Must
FR2	`cwalld` must monitor all operations made by subjects across a given directory.	Must
FR3	`cwalld` must make decisions based on subject label and object label aligned with the Chinese Wall policy.	Must
FR4	`cwalld` must alter the labels of subjects at upon call.	Must
FR5	`cwalld` must be accompanied by policy modules for objects.	Must
FR6	`cwalld` must be accompanied by policy modules for subjects.	Must
FR7	`cwalld` should be confined by SELinux with its own custom policy.	Should
FR8	`cwalld` should run as a service in the system with its own service declaration file.	Should
FR9	`cwalld` should write all operations to a log.	Should
FR10	`cwalld` should include a binary to follow and display the log in real time.	Should
FR11	`cwalld` could automatically create necessary policy modules for its runtime.	Could
FR12	`cwalld` could automatically install necessary policy modules before running.	Could
FR13	`cwalld` could dynamically enforce the policy given a set of `CoI` classes as input.	Could
FR14	`cwalld` won't enforce the Chinese Wall policy system-wide.	Won't

Table 1: Functional Requirements

Code	Requirement	Priority
NFR1	`cwalld` shall solely be controlled by the super-user.	Must
NFR2	`cwalld` shall run as a daemon in user-space of the computer.	Should
NFR3	`cwalld` shall be written with structural, intentional and idiomatic code.	Should
NFR4	`cwalld` shall be a good UNIX citizen, following classic system conventions.	Should
NFR5	`cwalld` shall function as intended across both x86 and ARM architecture.	Should
NFR6	`cwalld` shall act atomically, ensuring the Chinese Wall is instantaneous.	Could

Table 2: Non-Functional Requirements

4 Design

4.1 Virtual SELinux Environment

To develop and test on SELinux, the required environment is necessary. RHEL was chosen, as it is the most commonly used SELinux distribution. Fedora was also considered; a popular fork of Red Hat skewed towards personal workstations rather than enterprise servers. As RHEL is an enterprise product, the Red Hat Developer program was to be joined for free access. Once a key was acquired, a virtual machine was created using KVM, *Quick Emulator* (QEMU) and *Virt Manager* to interface with the virtual machine.

An *ssh reverse tunnel*, allowed the virtual machine to be navigated from the command line of the host machine. RHEL 9 and RHEL 10 were both used for experimentation, RHEL 9 being used after the instance of RHEL 10 was bricked during testing. System specifications can be seen here: 12.

4.2 Policy Design

To demonstrate the Chinese Wall Model in SELinux, the minimum amount of labels necessary to capture all use cases of the wall was designed. The model was designed such that there would be 3 object classes, 2 of which were in a `CoI` relation, and one which was not.

4.2.1 Object Policy Modules

A unique PM had to be installed for each different `CoI` type. The object PMs were simple, as they only needed to introduce the type to the system. This allowed the subject PMs to be reference the objects. The following types were to be introduced:

- `alpha_t`
- `beta_t`
- `gamma_t`
- `sanitised_t`

4.2.2 Subject Policy Modules

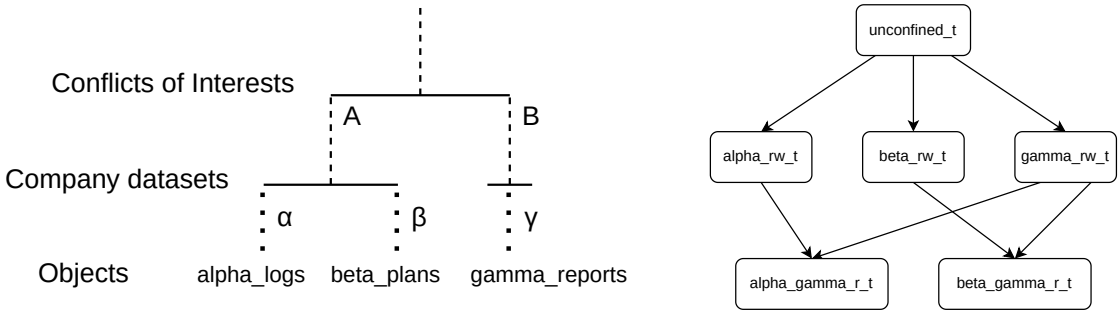
By default, SELinux restricts all actions that aren't granted in some PM. Thus, design of subject PMs must explicitly grant the object operations they shall allow. Six labels are included in the design.

These labels may be unconventional, for instance, why is it that `alpha_rw_t` can read from `gamma_t`? SELinux is preventative; the standard Wall method of a subject *asking* for permission to access an object or subject is just not possible. As such, the enforcement involves allowing the subject to

Label	alpha_t	beta_t	gamma_t	sanitised_t
unconfined_t	r/w	r/w	r/w	r/w
alpha_rw_t	r/w		r	r
beta_rw_t		r/w	r	r
gamma_rw_t	r	r	r/w	r
alpha_gamma_r_t	r		r	r
beta_gamma_r_t		r	r	r

Table 3: Table of subject labels and their granted operations

access anything that it *could*, instantly altering its label afterwards. When a subject with label alpha_rw_t *can* reads from gamma_t, its label instantly transitions to alpha_gamma_r_t, revoking its write access to alpha_t forever.



(a) Object structure (b) Subject label transition lattice

Figure 5: SELinux Chinese Wall

4.2.3 cwalld Policy Module

A policy module had to be constructed to encompass the runtime binary of the Chinese Wall Daemon. Once all of the functionality of the daemon was complete, SELinux was set to *permissive* mode, where all denials would be logged but not enforced. This meant that all needed grants were stored, and the *audit2allow* command was leverage to create a policy module for said grants. The PM was not complete however, as the final product involved behaviour that would only be executed if a denial was enforced. Such additions to the policy module were found by experimentation, trial and error.

4.3 System Design

4.3.1 Tailing the Audit Daemon

The central idea of the Chinese Wall Daemon surrounds tailing the *auditd* daemon log. A system daemon enabled by default in SELinux distributions and included in regular distributions, the *Linux Auditing Daemon* is capable of documenting every system call in the system, ranging from reads, writes, SELinux denials and everything else. A rule can be added to */etc/audit/rules.d/audit.rules*, one of which can make *auditd* audit every operation in a given directory. This feature would be key in surveilling a certain directory as was outlined as a requirement in *FR2*. The information in the *auditd* log includes the following information, necessary for cwalld: (see Figures: 13, 14 & 15 in appendix)

SYSCALL audit:

- Subject process ID
- Subject command
- Subject label
- Subject entrypoint
- Operation
- Operation success

PATH audit:

- Object path
- Object label

AVC audit:

- Specific operation denied

By parsing and combining this information at runtime, subjects in the system can be profiled, and had their operations and history precisely tracked. The logic for restrictions could then be handed to the Chinese Wall enforcement for a decision to be made.

4.3.2 Subject Label Alteration at Runtime

While a subject label can be detected at runtime with the *ps -efZ* command, this label is actually impossible to change. In SELinux, to change the security context of a subject, the label of the *entrypoint*[3] must be altered, allowing for the subject to transition into the new label domain once it is restarted. This means the Daemon will have to maintain a connection to the system *D-Bus*, to restart daemons at will.

[3]The entrypoint is the binary in the system that executes the subject. It behaves like any other object.

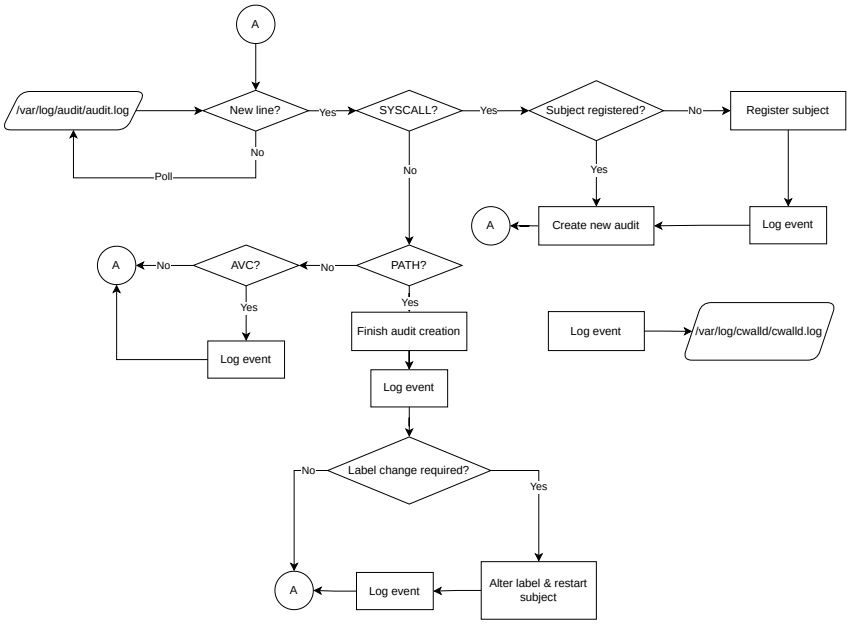


Figure 6: Flowchart

4.3.3 Flowchart

A flowchart was designed to capture the flow of the daemon:

The flowchart (illustrated in Figure 6) represents the central logic loop that surrounds tailing the *audit.log* file. The design of this flowchart would lead production throughout multiple iterations.

4.3.4 UML Diagram

To assist in development, a UML diagram was produced. (see Figure 8 in appendix for full size) This UML diagram was repeatedly addressed and iterated upon throughout development.

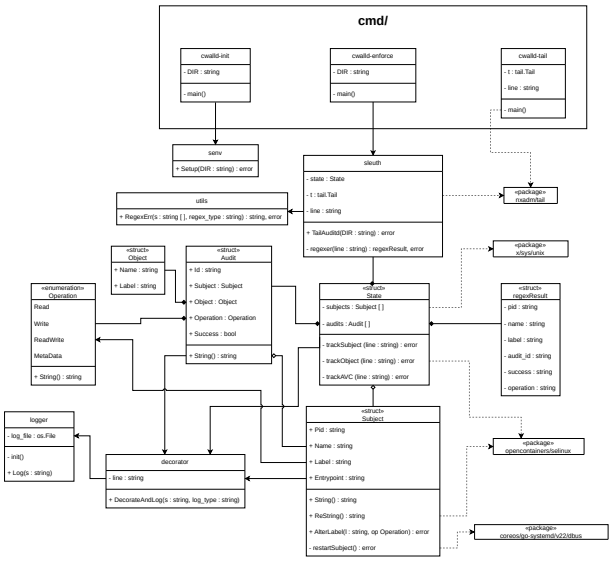


Figure 7: cwalld UML diagram

4.4 Assisting Binaries

As the Chinese Wall Daemon will be integrated into the system, there are to be assisting binaries to fulfill *FR1* & *FR10*. The two assisting binaries are:

4.4.1 cwalld-init

The Chinese Wall Daemon *Init* binary should set up the audit rule, that will make auditd audit everything in a given directory. It also should include a flag to alter the *cache threshold* of SELinux, allowing the AVC to print every denial in real time, at the cost of performance. This flag should only be used for demonstration purposes.

4.4.2 cwalld-tail

The Chinese Wall Daemon *Tail* binary should automatically tail and return every line that is logged in */var/log/cwall/cwall.log*. This allows us to track the cwalld-*enforce* in real-time as it tracks operations and alters labels.

5 Implementation

5.1 Technology Selection

5.1.1 Language

Go *(or Golang)* was chosen for the development of the Chinese Wall Daemon, due to its strong affinity with system-level programming. Go's advantages in systems engineering range from such:

- **Systems Origin:** Go was developed with systems programming at its core, remaining unpunishing while giving the developer great versatility and library access.
- **Performance:** As a compiled language, the flexibility to be built into a binary means minimal overhead at runtime. Go promises low-latency, high-performance applications.
- **Modernity:** Go is a modern alternative to the otherwise stagnant systems engineering environment. The focus on clean, idiomatic code with statically enforced typing means debugging can be trivial if common practice is followed.
- **Familiarity:** The simplicity of Go discourages unnecessary complexity while promoting hands-on learning. Repeated experience working with the language supported the choice and guaranteed steady progress in the venture.

5.1.2 Packages

nxadm/tail

A fork of the deprecated tail package by *hpcloud*, *nxadm* provides a Tail object that can be used to tail a specified file. Tailing a file involves effectively attaching a process to a file (typically a log file), and returning updates in real time. It allows a program to closely monitor a file for its own needs. The package leverages *fsnotify* to instantly recognise file updates, also providing truncation/move support, allowing it to follow rotating log files with minimal configuration.

opencontainers/selinux

The *selinux* package provides a direct route for Go make SELinux system calls to the kernel, necessary for operations such as *chcon* (change context, i.e label of an object) and the *-Z* flag for acquiring label information. It also provides native error handling to Go, streamlining usage and debugging.

x/sys/unix

The official Go Project *sys/unix* package introduces a layer of abstraction over both *x86* and *ARM* architecture system call codes, providing a unified interface for detecting system operations.

coreos/go-systemd

go-systemd introduces tools to manage a connection directly to the system *D-Bus*. This allows direct communication with operations typically managed with *systemctl*, such as starting and stopping services on a system.

5.2 Version Control

Git was heavily used throughout the project as the primary version control measure. It allows incremental development across multiple devices, which would be critical for splitting development between SELinux and the host machine.

It also kept a backlog of all changes, allowing changes to be reverted if found to be problematic. This gave the project a guarantee, where experimentation could flourish without risk of permanent damage.

5.3 Policy Modules

Object PMs simply instantiate the domain for the system.

```
module beta 1.0;

type beta_t;

files_type(beta_t)
```

Code Block 1: Object Declarations (*beta.te* file)

The `files_types` macro is shorthand for defining the label globally as a file type.

PMs had to be created and compiled for $5/6$ of the labels in in Figure 5b.

Subject PMs must start by requiring every type they use:

```
1 require {
2   type beta_t;
3   type gamma_t;
4   type sanitised_t;
5   type user_home_t;
6 }
```

Code Block 2: Subject Declarations

The subject must also require `user_home_t`, as it is needed to be granted navigational privileges.

The subject PMs also require the following lines:

```
1 init_daemon_domain(beta_rw_t, beta_rw_exec_t)
2
3 allow beta_rw_t self:fifo_file rw_fifo_file_perms;
4 allow beta_rw_t self:unix_stream_socket create_stream_socket_perms;
5
6 allow beta_rw_t user_home_t:dir { search read open write add_name };
```

Code Block 3: Subject Necessities

`init_daemon_domain` is a macro for standard daemons. It's used in every subject label made.

Lines 3 & 4 are for daemons communicating with *FIFO* files and things like *D-Bus* & the kernel. Standard SELinux daemon requirements.

Line 6 allows the subjects to navigate diretories with the `user_home_dir_t` label. They need to have permission to *add_name* as well, as writing files in SELinux periodically requires that permission.

Second layer subject PMs

The second lattice layer consisted of the labels:

- `alpha_rw_t`
- `beta_rw_t`
- `gamma_rw_t`

```
1 allow beta_rw_t beta_t:file { read write getattr open };
2 allow beta_rw_t gamma_t:file { read getattr open };
3 allow beta_rw_t sanitised_t:file { read getattr open };
```

Code Block 4: 2nd lattice layer labels

In SELinux PMs, *getattr* & *open* must be included to grant *read* privileges.

Third layer subject PMs

The third lattice layer consisted of the labels:

- alpha_gamma_r_t
- beta_gamma_r_t

```
allow alpha_gamma_r_t alpha_t:file { read getattr open };
allow alpha_gamma_r_t gamma_t:file { read getattr open };
allow alpha_gamma_r_t sanitised_t:file { read getattr open };
```

Code Block 5: 3rd lattice layer labels

Post-installation of those subjects, everything is in place for the Chinese Wall Daemon.

5.4 Internal Packages

Sleuth

The center of cwalld is *sleuth.go* module. Sleuth holds reference to a single state struct, which holds a slice[4] of subjects, and a slice of audits.

```
type State struct {
  subjects []subject.Subject
  audits []audit.Audit
}
```

The state struct has the three main methods that lines tailed from auditd are sent to:

- trackSubject()
- trackObject()
- trackAVC()

First, the tail must be instantiated. The following code creates a tail *t* and sets the following flags

```
t, err := tail.TailFile("/var/log/audit/audit.log", tail.Config{
  Follow: true, // keep reading new lines
  ReOpen: true, // follow & reopen new log rotations
  Location: &tail.SeekInfo{ Offset: 0, Whence: io.SeekEnd }})
```

[4] Go calls arrays 'slices'

Subject

Audit

SEnv

Decorator & Logger

.service file

6 Verification & Validation

6.1 Testing Suite

- Unit testing (code coverage etc)
- Fitness testing (does it correctly relabel all the testing daemons...)

6.2 Testing Constraints

- Benchmark testing
  - Time it takes to change labels
  - Amount of services it can handle at once

How did you verify that your software was debugged and worked correctly? How did you validate that you had implemented all the functional and non-functional requirements?

7 Results & Evaluation

Results are often presented in tables, figures and other relevant illustrations. Include text that refers to these figures/tables.

7.1 Evaluation Process

If you involved humans in the evaluation, how many did you have? What can you say about the demographics of your participants? (If you did collect these) In terms of the user interface, how did you carry out a usability evaluation, how did you go about doing this? How did you recruit participants? In terms of delivering functionality, did you carry out user acceptance testing? (see attached guidance).

7.2 Results of Evaluation

This Section includes a direct interpretation of the gathered data and evaluation processes.

7.3 Returning to the Research Questions

Return to research questions or objectives as appropriate.

7.3.1 RQ1

It is clear from our findings that James Bond was born in Wigtown in Scotland. However, he grew up in Diss, in Norfolk. We know this because ....

7.3.2 RQ2

We were not able to answer this question from our studies, although some suggestions were made. These could not be proven.

7.3.3 Objective 1

7.3.4 Objective 2

8 Discussion & Reflection

8.1 Interpreting the Results

Here you will discuss your findings. This is especially relevant for research projects. You might interpret what the data and evaluation implies, both for future research and for practice (if appropriate). The discussion is not a review of literature. You should try to compare research findings with previous work, provide explanations for your findings, discuss research findings, in terms of their contribution.

8.2 Reflection

Look back and think about what you would do differently if you were going to start the project with the knowledge you have now. Be honest about your mistakes or missteps.

8.3 Challenges

This is not the place to mention personal circumstances but rather challenges related to the work involved in the project.

8.4 Limitations

Acknowledge things like: small number of participants, software wasn't completely debugged, or whatever else went wrong and affected your project. Include as appropriate

8.5 Future Work

If someone else wanted to build on your project's product, what would be cool to do next?

9 Conclusion

The conclusion is similar to when a plane lands. You don't rewrite the introduction. You say something like - I addressed the problem outlined in the introduction, and I built some software to do this. I tested the software like this ADD FEW WORDS. Summarize main findings drawn from the project work. Mention the objectives or research questions. Do not repeat points raised in the discussion and reflection Section. If applicable, you can make recommendations. The conclusion should NOT contain any references.

References

[1] D. Brewer and M. Nash, "The chinese wall security policy," in *Proceedings. 1989 IEEE Symposium on Security and Privacy*, pp. 206–214, IEEE Comput. Soc. Press.

[2] "Red hat enterprise linux | red hat partner connect."

[3] D. E. Bell and L. J. Lapadula, "Secure computer systems: Mathematical foundations," Number: MTR2547VOL1.

[4] T. Y. Lin, "Chinese wall security policy-an aggressive model," pp. 282,283,284,285,286,287,288,289–282,283,284,285,286,287,288,289, IEEE Computer Society.

[5] S. N. Foley, "Building chinese walls in standard unixTM," vol. 16, no. 6, pp. 551–563.

[6] Y. Fan, Z. Han, J. Liu, and Y. Zhao, "A mandatory access control model with enhanced flexibility," in *2009 International Conference on Multimedia Information Networking and Security*, vol. 1, pp. 120–124. ISSN: 2162-8998.

[7] R. Sailer, T. Jaeger, E. Valdez, R. Caceres, R. Perez, S. Berger, J. Griffin, and L. van Doorn, "Building a MAC-based security architecture for the xen open-source hypervisor," in *21st Annual Computer Security Applications Conference (ACSAC'05)*, pp. 10 pp.–285. ISSN: 1063-9527.

[8] T.-H. Tsai, Y.-C. Chen, H.-C. Huang, P.-M. Huang, and K.-S. Chou, "A practical chinese wall security model in cloud computing," in *2011 13th Asia-Pacific Network Operations and Management Symposium*, pp. 1–4.

[9] S. Yu, X. Gui, J. Lin, F. Tian, J. Zhao, and M. Dai, "A security-awareness virtual machine management scheme based on chinese wall policy in cloud computing," vol. 2014, no. 1, p. 805923. _eprint: https://onlinelibrary.wiley.com/doi/pdf/10.1155/2014/805923.

[10] Y.-C. Hsiao and G.-H. Hwang, "Implementing the chinese wall security model in workflow management systems," in *International Symposium on Parallel and Distributed Processing with Applications*, pp. 574–581. ISSN: 2158-9208.

[11] L. Herzel and D. E. Colling, "The chinese wall and conflict of interest in banks," vol. 34, no. 1, pp. 73–115. Publisher: American Bar Association.

[12] K. A. Khan, M. Amin, A. K. Afridi, and W. Shehzad, "SELinux in and out," in *2011 IEEE 3rd International Conference on Communication Software and Networks*, pp. 339–343.

[13] S. Smalley, "Configuring the SELinux policy,"

[14] P. A. Loscocco and S. D. Smalley, "Meeting critical security objectives with security-enhanced linux,"

[15] L. T. Koehler, "Linux: An operating system," vol. 5, no. 1, pp. 136–141. Num Pages: 6.

[16] B. Sarna-Starosta and S. D. Stoller, "Policy analysis for security-enhanced linux,"

[17] H. James, "85% of all smartphones are powered by linux."

[18] "Can the internet exist without linux? | ZDNET."

[19] "Red hat: Leading the enterprise linux server market."

A Appendix

A.1 cwalld design

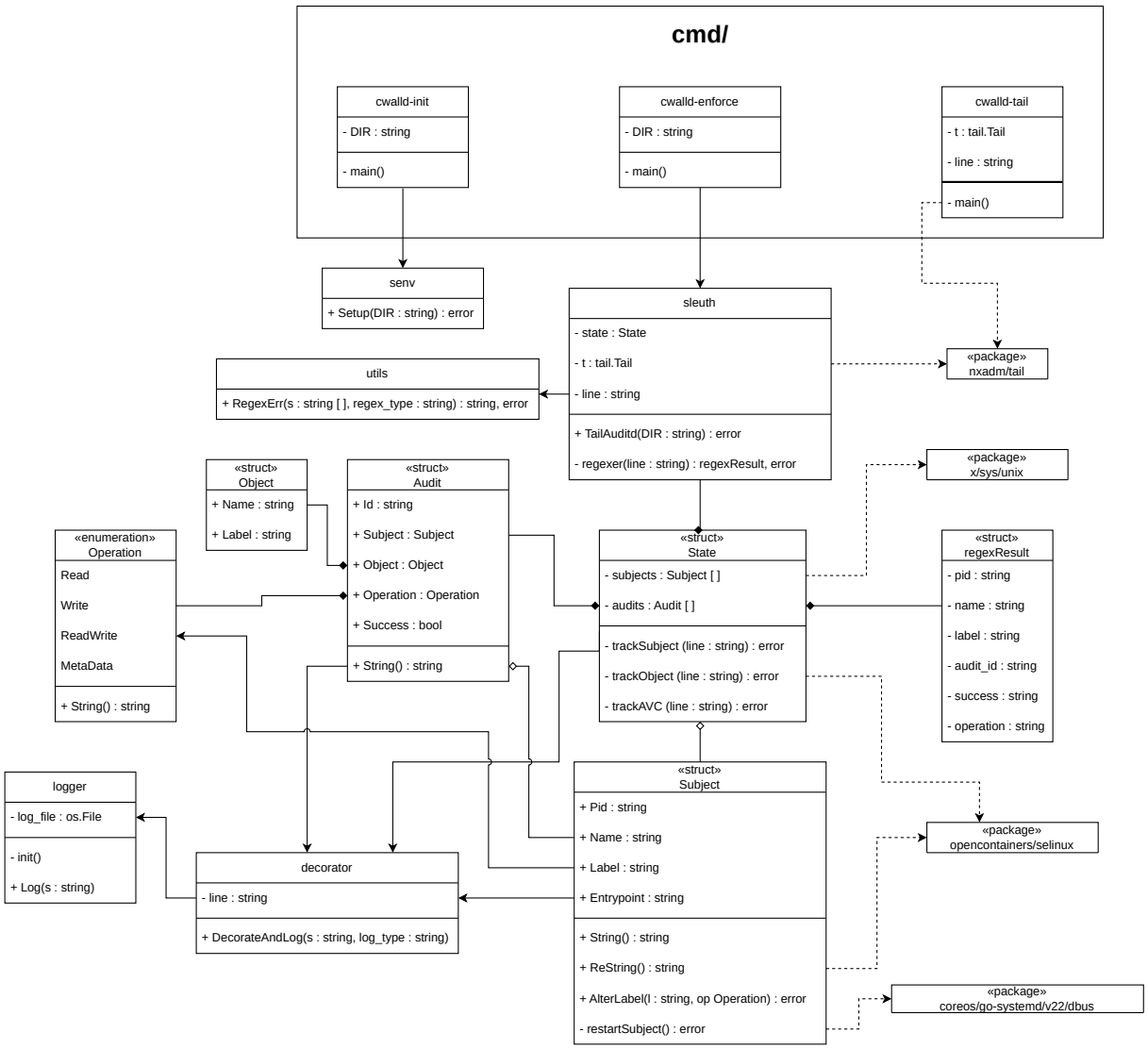


Figure 8: cwalld UML diagram

A.2 Policy Modules

```
module alpha 1.0;

type alpha_t;

files_type(alpha_t)
```

Figure 9: *alpha.te* file

```
policy_module(alpha_rw, 1.0.0)

########################################
#
# Declarations
#

type alpha_rw_t;
type alpha_rw_exec_t;

require {
	type alpha_t;
	type gamma_t;
	type sanitised_t;
	type user_home_t;
}

init_daemon_domain(alpha_rw_t, alpha_rw_exec_t)

########################################
#
# alpha_rw local policy
#
allow alpha_rw_t self:fifo_file rw_fifo_file_perms;
allow alpha_rw_t self:unix_stream_socket create_stream_socket_perms;

# cwalld policies
allow alpha_rw_t alpha_t:file { read write getattr open };
allow alpha_rw_t gamma_t:file { read getattr open };
allow alpha_rw_t sanitised_t:file { read getattr open };

# navigational policies
allow alpha_rw_t user_home_t:dir { search read open write add_name };

```

Figure 10: *alpha_rw_t .te* file

A.3 Red Hat

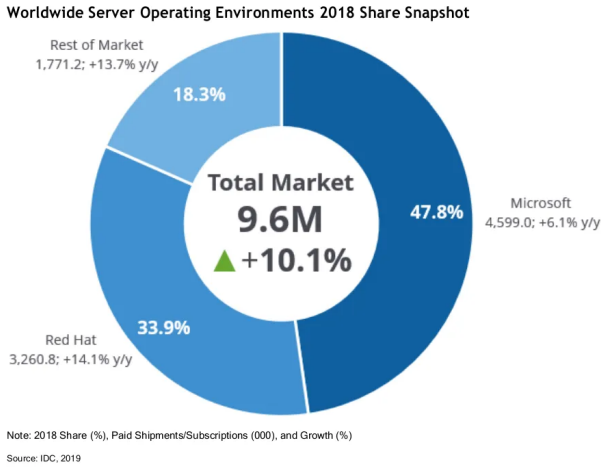


Figure 11: Red Hat statistics

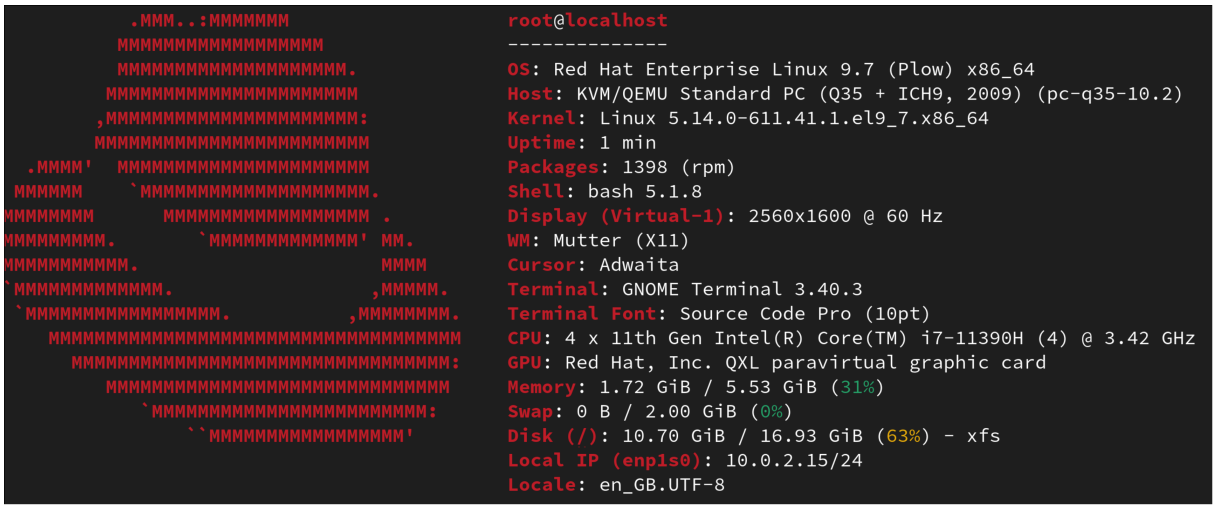


Figure 12: Virtual Machine Red Hat System Specifications

A.4 Auditd logs

```
type=SYSCALL msg=audit(1774217186.548:210): arch=c000003e syscall=257 success=yes exit=3 a0=ffffff9c
a1=402018 a2=241 a3=1b6 items=2 ppid=1 pid=3299 auid=4294967295 uid=0 gid=0 euid=0 suid=0 fsuid=0 egi
d=0 sgid=0 fsgid=0 tty=(none) ses=4294967295 comm="alpha_civild" exe="/usr/local/bin/alpha_civild" su
bj=system_u:system_r:unconfined_service_t:s0 key="cwalld"
```

Figure 13: Example auditd SYSCALL audit

```
type=PATH msg=audit(1774217339.211:13879): item=0 name="/home/testgrounds/objects/alpha_logs" inode=5
8142854 dev=fd:00 mode=0100666 ouid=1000 ogid=1000 rdev=00:00 obj=unconfined_u:object_r:alpha_t:s0 na
metype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0
```

Figure 14: Example auditd PATH audit

```
type=AVC msg=audit(1774217334.204:13868): avc:  denied  { read } for  pid=3485 comm="beta_evild" name
="alpha_logs" dev="dm-0" ino=58142854 scontext=system_u:system_r:beta_rw_t:s0 tcontext=unconfined_u:o
bject_r:alpha_t:s0 tclass=file permissive=0
```

Figure 15: Example auditd AVC audit

```
policy_module(cwalld, 1.0.0)

type cwalld_t;
type cwalld_exec_t;

require {
  type proc_t;
  type alpha_rw_exec_t;
  type beta_rw_exec_t;
  type gamma_rw_exec_t;
    type sysfs_t;
    type bin_t;
    type unconfined_t;
    type system_dbusd_t;
    type system_dbusd_var_run_t;
    type unconfined_service_t;
    type init_t;
    type systemd_unit_file_t;
    type unlabeled_t;
    type auditd_log_t;
    type cgroup_t;
    type user_home_t;
  type var_log_t;
  type sanitised_t;
    class process getattr;
    class capability { dac_read_search sys_admin sys_ptrace };
    class file { append execute execute_no_trans getattr map open
       read relabelfrom relabelto watch };
    class dir { getattr search };
    class lnk_file read;
    class filesystem mount;
    class sock_file write;
    class unix_stream_socket connectto;
    class dbus send_msg;
    class service start;
```

```
}

init_daemon_domain(cwalld_t, cwalld_exec_t)

#============= cwalld_t ==============
allow cwalld_t auditd_log_t:dir search;
allow cwalld_t auditd_log_t:file { getattr open read watch };
allow cwalld_t bin_t:file relabelfrom;
allow cwalld_t cgroup_t:dir search;
allow cwalld_t cgroup_t:file { open read };
allow cwalld_t init_t:dbus send_msg;
allow cwalld_t proc_t:filesystem mount;
allow cwalld_t self:capability { dac_read_search dac_override
    sys_admin sys_ptrace };
allow cwalld_t self:process getattr;
allow cwalld_t sysfs_t:file { open read };
allow cwalld_t system_dbusd_t:dbus send_msg;
allow cwalld_t system_dbusd_t:unix_stream_socket connectto;
allow cwalld_t system_dbusd_var_run_t:dir search;
allow cwalld_t system_dbusd_var_run_t:sock_file write;
allow cwalld_t systemd_unit_file_t:service start;
allow cwalld_t var_log_t:dir { create write add_name };
allow cwalld_t var_log_t:file { create write open getattr setattr };
allow cwalld_t unconfined_service_t:dir search;
allow cwalld_t unconfined_service_t:file { open read relabelfrom
    relabelto };
allow cwalld_t unconfined_service_t:lnk_file read;
allow cwalld_t unconfined_service_t:process getattr;
allow cwalld_t unconfined_t:dir search;
allow cwalld_t unconfined_t:file { open read };
allow cwalld_t unconfined_t:lnk_file read;
allow cwalld_t unconfined_t:process getattr;
allow cwalld_t user_home_t:dir { getattr search };

allow cwalld_t file_type:file { relabelto relabelfrom setattr
```

```
      getattr };
allow cwalld_t file_type:dir { relabelto relabelfrom setattr getattr
       };
allow cwalld_t file_type:lnk_file { relabelto relabelfrom setattr
      getattr };
allow unconfined_t cwalld_exec_t:file { read execute open getattr };
allow cwalld_t domain:file { read open getattr };
allow cwalld_t domain:dir { search getattr };
allow cwalld_t domain:lnk_file read;
allow cwalld_t domain:process getattr;

#============= init_t ==============
allow init_t auditd_log_t:file { open read watch };
allow init_t cwalld_t:dbus send_msg;
```

Code Block 6: *Cwalld_t.te*